
1. Comment ça fonctionne ?

Suricata peut fonctionner de deux manières différentes :

- **Mode IDS (Intrusion Detection System)** : Il "écoute" une copie du trafic. S'il détecte quelque chose de suspect (via sa base de signatures), il génère une alerte dans les journaux, mais **ne bloque rien**. C'est le mode idéal pour commencer sans risquer de couper internet à tout le monde.
- **Mode IPS (Intrusion Prevention System)** : Il se place "au milieu" du flux de données. S'il détecte une menace, il **bloque immédiatement** le paquet. Cela demande plus de ressources (CPU/RAM) et une configuration plus fine pour éviter les "faux positifs" (bloquer un site légitime par erreur).

2. Étapes d'installation et configuration

Étape A : Activation du service

1. Allez dans **Services > Intrusion Detection > Administration**.
2. Cochez **Enabled** (Activer).
3. Sélectionnez l'interface à surveiller (généralement **WAN** pour surveiller ce qui vient d'Internet, ou **LAN** pour surveiller ce qui se passe à l'intérieur).
4. Cochez **Promiscuous Mode** pour que Suricata puisse voir tout le trafic sur l'interface.

Étape B : Téléchargement des règles (Signatures)

Suricata est "aveugle" sans règles. Vous devez lui dire quoi chercher.

1. Allez dans l'onglet **Download**.
2. Cherchez les règles gratuites comme **ET Open** (Emerging Threats). Cochez les catégories qui vous intéressent (malware, scan, trojans, etc.).
3. Cliquez sur **Enable selected** puis sur **Download & Update Rules**.

Étape C : Automatisation des mises à jour

Les cybermenaces évoluent tous les jours. Allez dans l'onglet **Schedule** pour créer une tâche (Cron) qui mettra à jour vos règles automatiquement (par exemple, une fois par jour).

3. La stratégie recommandée (Le "Dry Run")

N'activez pas le mode **IPS** tout de suite. Voici la méthode pro :

1. **Phase d'observation (1 à 2 semaines)** : Laissez Suricata en mode **IDS** uniquement.
2. **Analyse des alertes** : Allez régulièrement dans **Services > Intrusion Detection > Alerts**. Si vous voyez des alertes pour des choses que vous utilisez (par exemple, un jeu vidéo ou

un logiciel métier), désactivez la règle spécifique pour éviter les futurs blocages.

3. **Passage en IPS** : Une fois que vos alertes sont "propres", retournez dans l'onglet **Settings**, cochez **IPS mode**, et assurez-vous de changer l'action des règles de "Alert" vers "Drop" pour bloquer activement.

Point d'attention : Le matériel

Suricata analyse chaque paquet en profondeur. Si vous avez une connexion fibre 1 Gbps, il vous faudra un processeur correct (type Intel i5 ou récent) et au moins 8 Go de RAM pour ne pas brider votre débit.

Souhaitez-vous de l'aide pour choisir les ensembles de règles (Rulesets) les plus adaptés à votre usage (domestique vs serveur exposé) ?

1. Les indispensables (Sécurité Générale)

Ces règles sont peu gourmandes et ciblent les menaces les plus communes :

- **ET open/emerging-botcc** (Botnet Command & Control) : Bloque les communications vers les serveurs de pirates connus.
- **ET open/emerging-malware** : La base pour détecter les virus et logiciels malveillants.
- **ET open/emerging-trojan** : Détecte les chevaux de Troie.
- **ET open/emerging-worm** (Visible sur ta capture) : Pour les vers informatiques qui tentent de se propager.
- **ET open/threatview_CS_c2** (Visible sur ta capture) : Très efficace contre les outils de type Cobalt Strike utilisés par les hackers.

2. Si tu navigues sur le web (Protection Clients)

Pour protéger les PC et smartphones de ta famille/collègues :

- **ET open/emerging-web_client** (Visible sur ta capture) : Protège contre les sites piégés qui exploitent les failles des navigateurs.
- **ET open/emerging-user_agents** (Visible sur ta capture) : Détecte les navigateurs bizarres ou outils de hacking qui tentent de sortir.

3. Si tu héberges des serveurs (Protection Serveurs)

N'active ceux-là que si tu as ouvert des ports (ex: port 80, 443) vers un NAS, un site web ou un serveur Nextcloud :

- **ET open/emerging-web_server** : Attaques génériques contre les serveurs web.
 - **ET open/emerging-sql** : Tentatives d'injections SQL sur tes bases de données.
 - **ET open/emerging-exploits** : Tentatives d'exploitation de vulnérabilités connues.
-

 Mes conseils pour ne pas "casser" ton internet :

- **Évite emerging-scan au début** : C'est extrêmement bavard. Internet est scanné en permanence par des robots inoffensifs. Si tu l'actives, ton journal d'alertes va exploser en 5 minutes.
- **Évite emerging-games ou emerging-p2p** : Sauf si tu veux interdire les jeux vidéo ou le téléchargement (Torrent) sur ton réseau.
- **La procédure :**
 1. Coche les cases de la liste ci-dessus.
 2. Clique sur **Enable selected**.
 3. Clique sur **Download & Update Rules** (en haut de la page).
 4. Va dans l'onglet **Rules** pour vérifier qu'elles sont bien chargées.